SECURITY BRIEF

GitHub access for Contica Test Tool

Setup and security overview for your GitHub admin and security team.

Contica Test Tool

Contica Test Tool is a Visual Studio Code extension that testers use to analyse integrations and generate test packs. It reads and updates a shared **bundle repository** on GitHub. It reaches GitHub **only** through the **Contica Test Tool Bundle Sync** GitHub App, which your organisation installs on the bundle repository and nowhere else.

Only the repos you choose

The App reaches only the repositories your admin installs it on, and only for testers who can reach those repositories themselves.

One permission

Repository contents: read and write. Nothing else: no issues, pull requests, workflows, administration or organisation settings.

No secrets in the extension

Sign-in uses GitHub's device flow with the App's public Client ID. The App has no private key and no client secret.

Nothing goes to Contica

There is no Contica server. Tokens go from github.com to the tester's VS Code and back to github.com.

Short-lived tokens

The access token the tool works with lasts 8 hours and is renewed in the background. A tester who does not use the tool for 6 months must sign in again.

You can cut it off at once

Uninstall the App, or remove a repository from it, and access ends on the next pull or push.

What to do (two steps)

1. **Install the App on the bundle repository only.**
   Open https://github.com/apps/contica-test-tool-bundle-sync and click **Install** (or go straight to https://github.com/apps/contica-test-tool-bundle-sync/installations/new). Choose your organisation, pick **Only select repositories**, and select the bundle repository or repositories. Leave every other repository out.

2 **Recommended: block personal access tokens for your organisation.**
In GitHub, open your organisation → **Settings** → **Personal access tokens** → **Settings**, and choose **Restrict access via personal access tokens**.
The tool itself never uses personal tokens. This setting goes further: GitHub then refuses every personal token (classic and fine-grained) on your organisation's repositories, for any tool or script. It is enforced by GitHub, so nothing on a tester's computer can get around it.

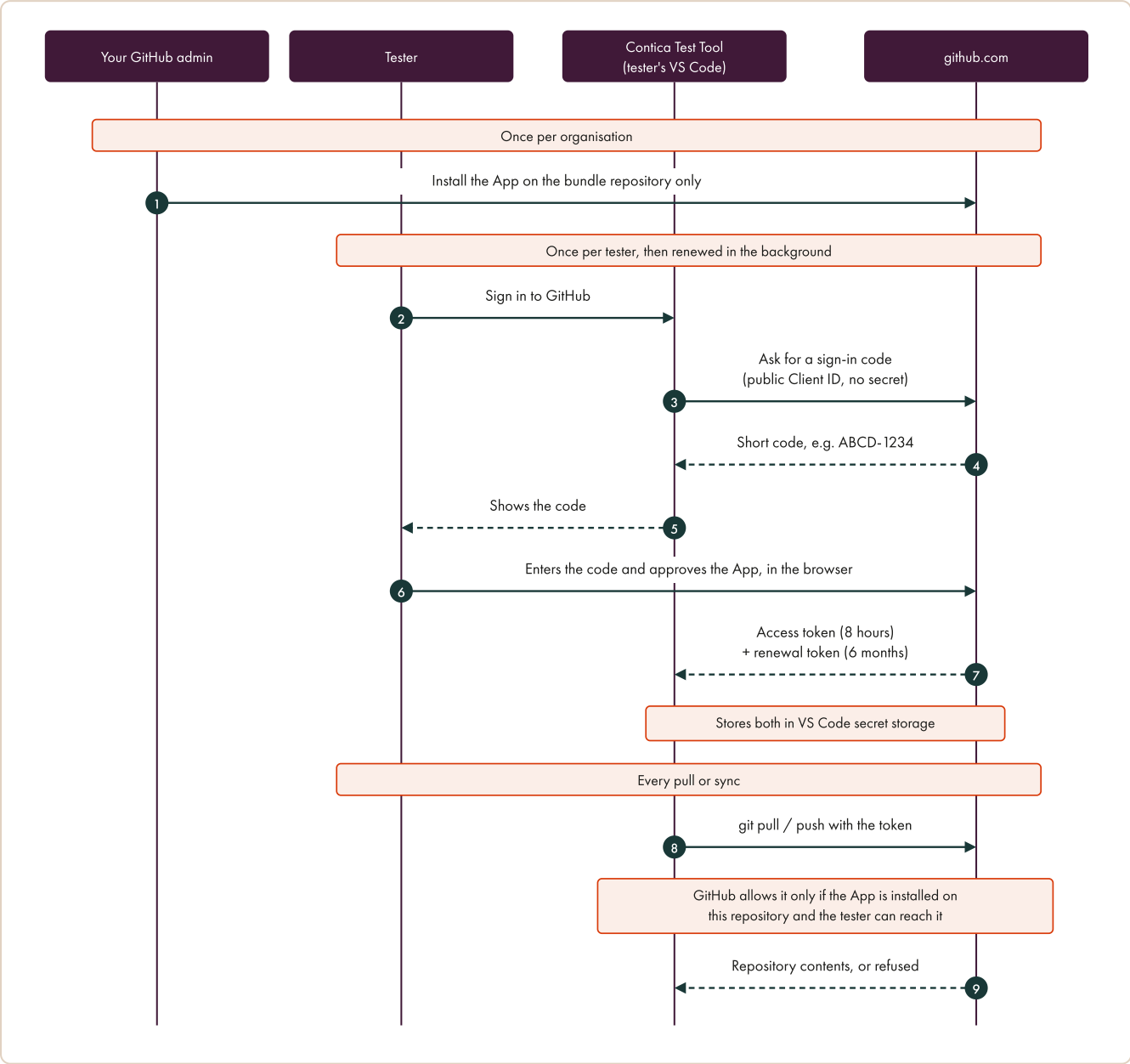
That is all. Testers then click **Sign in to GitHub** in the tool and approve the App on github.com once.

What the App can and cannot do

Area	What it means
Repositories	Only the ones your organisation installs the App on, and of those only the ones the signed-in tester can also reach.
Permissions	Contents: read and write. Metadata: read, which GitHub adds to every App. Nothing else.
Who it acts as	Always a signed-in tester. GitHub attributes every change to that tester, made through the Contica Test Tool Bundle Sync app.
Tokens	An access token (8 hours) for reading and writing the repository, and a renewal token (6 months) that can only get a new access token. See "Two tokens, two jobs". Both are kept in VS Code's secret storage (the operating system's credential store) and are sent only to github.com and api.github.com.
Private key, client secret	None exist. Nothing can act as the App without a signed-in tester.
Data to Contica	None. There is no Contica server.
Permission changes	If Contica ever asked for more permissions, GitHub would ask your organisation owner to approve the change before it applied to your installation.
Other sign-ins	The tool never uses personal access tokens, VS Code's own GitHub sign-in, or a GitHub login saved on the computer, because those reach every repository the tester can see.

How it works

Three parties are involved, and Contica is not one of them at run time: your GitHub admin, the tester's own VS Code, and github.com.



Two tokens, two jobs

Token	Valid for	What it is used for
Access token	8 hours	The only token that can read or write the bundle repository. The tool sends it with every pull and push. After 8 hours it no longer works.
Renewal token	6 months	Cannot read or write any repository. Its only use is to ask GitHub for a new access token for this App. Each time it is used, GitHub replaces it with a new one, so a tester who uses the tool at least once every 6 months stays signed in.

Both are kept in VS Code's secret storage on the tester's computer, are sent only to GitHub, and stop working at once when the tester signs out and revokes the App, or when your organisation uninstalls the App.

- **The App reaches only the repositories you installed it on**, and only for testers who can reach them. GitHub makes that check on every pull and push, not the tool.
- **You stay in control:** uninstalling the App, or removing a repository from it, takes effect on the next pull or push.

Removing access

- **For everyone:** organisation → Settings → **GitHub Apps** → Contica Test Tool Bundle Sync → **Uninstall**, or change its repository list. This takes effect straight away.
- **For one tester:** the tester clicks **Sign out of GitHub** under **GitHub** in the Contica Test Tool sidebar, and on GitHub goes to **Settings** → **Applications** → **Authorized GitHub Apps** → Revoke.

Using your own GitHub App instead

By default testers sign in with the Contica Test Tool Bundle Sync app and nobody has to enter any ID. If your policy requires an App your organisation owns, register one as below and point the tool at it. The extension works the same way; only the App it signs in with changes. You need to be an owner of your GitHub organisation. It takes about five minutes, needs no paid GitHub plan, and installs nothing: a GitHub App is a registration on GitHub (a name, one permission and an ID), not a program.

1. Open the form

Your organisation → **Settings** → **Developer settings** → **GitHub Apps** → **New GitHub App**.

2. Fill it in, top to bottom

Field	Set it to
GitHub App name	A name your testers will recognise. Names are unique across GitHub.
Homepage URL	Any page you own, for example your company website. Required by GitHub, not used by the tool.
Redirect URI	Leave empty. If an empty row is shown, click **Delete** next to it.
Expire user authorization tokens	Ticked.
Request user authorization (OAuth) during installation	Not ticked.
Enable Device Flow	**Ticked.** Without it, sign-in does not work.
Setup URL, Redirect on update	Leave empty and not ticked.
Webhook → Active	**Not ticked.** The App sends nothing anywhere.
Repository permissions → Contents	**Read and write.** Every other repository permission stays at No access. Metadata: Read-only is added by GitHub.

Organization, Account and Enterprise permissions	All No access.
Where can this GitHub App be installed?	**Only on this account.**

3. On the App's page

- Do **not** generate a private key or a client secret. The tool needs neither.
- Copy the **Client ID** (it starts with `Iv`). It is not secret. The page also shows an App ID, a plain number; that is not the one the tool needs.

4. Install it on the bundle repository only

On the App's page → **Install App** → your organisation → **Only select repositories** → the bundle repository → **Install**.

5. Point the testers' VS Code at it

Each tester opens VS Code **Settings**, searches for **GitHub App Client ID**, and pastes the Client ID. The setting is only read from the tester's own user settings, never from a settings file inside a project folder. Then they click **Sign in to GitHub** under **GitHub** in the Contica Test Tool sidebar.

> **Why the GitHub setting matters most.** A tester can change their own VS Code settings, and VS Code's enterprise policies cannot lock a third-party extension's settings. The controls to rely on are on GitHub: where the App is installed, and restricting personal access tokens for your organisation.
